



teknologi
informasi
UNIVERSITAS HUMANISTIK YOGYAKARTA

Modul Praktikum

Pengembangan Aplikasi Basisdata

Apriliya Kurnianti S.T., M.Eng



MODUL PRAKTIKUM 9

Advanced Database Security pada ADO.NET

MySQL Injection Attack & Defense Strategy

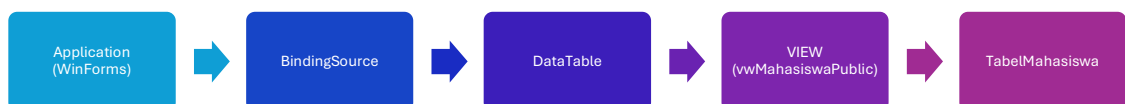
A. Tujuan

Setelah menyelesaikan praktikum ini mahasiswa mampu:

1. Memahami celah MySQL Injection
2. Mengamankan query dengan Parameterized Query
3. Menggunakan VIEW sebagai pembatas akses data
4. Mengintegrasikan BindingNavigator secara aman
5. Menerapkan konsep Defense in Depth

B. Arsitektur yang digunakan

Pada praktikum kali ini kita akan menggunakan arsitektur sebagai berikut:

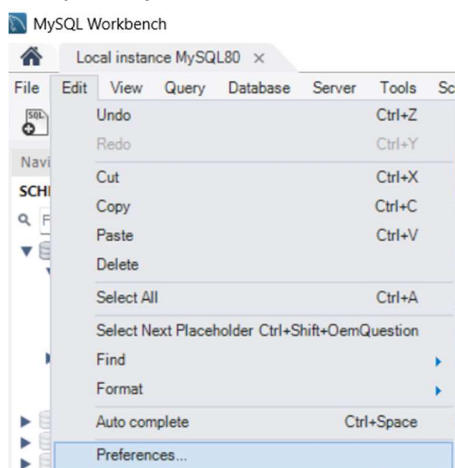


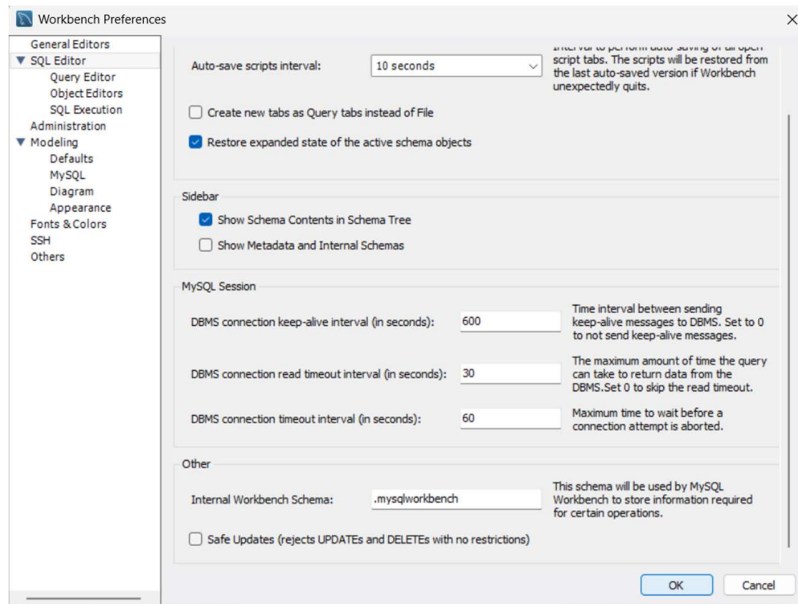
Sedangkan INSERT / UPDATE / DELETE tetap menggunakan parameterized query langsung ke tabel.

C. Praktikum

1. LANGKAH 1 – Ubah setingan MySQL Server

Buka Preferences... -> Buka MySQL Editor -> uncheck list Safe Update -> click Ok -> Reopen MySQL Workbench -> Reconnect Server.





2. LANGKAH 2 – Membuat VIEW

Jalankan query berikut setelah terkoneksi dengan mysql database server:

```
create view vwMahasiswaPublic as
select
    mahasiswa.NIM,
    mahasiswa>Nama,
    mahasiswa.JenisKelamin,
    mahasiswa.TanggalLahir,
    mahasiswa.Alamat,
    prodi>NamaProdi
from
    Mahasiswa
join
    prodi
on mahasiswa.KodeProdi = prodi.KodeProdi;
```

Tujuan:

- Membatasi data yang boleh ditampilkan
- Tidak memberikan akses langsung ke tabel

3. LANGKAH 3 – mengubah code event pada formMahasiswa_Load()

```
private void Form1_Load(object sender, EventArgs e)
{
    cmbJK.DataSource = new string[] { "L", "P" };

    dataGridView1.SelectionMode = DataGridViewSelectionMode.FullRowSelect;
    dataGridView1.MultiSelect = false;
    dataGridView1.ReadOnly = true;
    dataGridView1.AllowUserToAddRows = false;
    dataGridView1.AutoSizeColumnsMode = DataGridViewAutoSizeColumnsMode.Fill;

    bindingNavigator1.BindingSource = bindingSource1;

    LoadData();
}
```

4. LANGKAH 4 – mengubah code pada LoadData()

```
private void LoadData()
{
    try
    {
        conn.Open();

        da = new MySqlDataAdapter("SELECT * from vwMahasiswaPublic", conn);

        dtMahasiswa = new DataTable();
        da.Fill(dtMahasiswa);

        bindingSource1.DataSource = dtMahasiswa;
        dataGridView1.DataSource = bindingSource1;
    }
    catch (Exception ex) {
        MessageBox.Show("Gagal load data: " + ex.Message);
    }
}
```

5. LANGKAH 5 – Menambahkan bind control

```
private void BindControls()
{
    txtNIM.DataBindings.Clear();
    txtNama.DataBindings.Clear();
    cmbJK.DataBindings.Clear();
    dtpTanggalLahir.DataBindings.Clear();
    txtAlamat.DataBindings.Clear();
    txtKodeProdi.DataBindings.Clear();

    txtNIM.DataBindings.Add("Text", bindingSource1, "NIM");
    txtNama.DataBindings.Add("Text", bindingSource1, "Nama");
    cmbJK.DataBindings.Add("Text", bindingSource1, "JenisKelamin");
    dtpTanggalLahir.DataBindings.Add("Text", bindingSource1, "TanggalLahir");
    txtAlamat.DataBindings.Add("Text", bindingSource1, "Alamat");
    txtKodeProdi.DataBindings.Add("Text", bindingSource1, "NamaProdi");
}
```

6. LANGKAH 6 – Ubah code pada form()

```
public Form1()
{
    InitializeComponent();
}
```

7. LANGKAH 7 – Hapus method connectDatabase(), kemudian ubah event code pada btnConnect

```
private void btnConnect_Click(object sender, EventArgs e)
{
    try
    {
        using (MySQLConnection conn = new MySQLConnection(connectionString))
        {
            conn.Open();
            MessageBox.Show("Koneksi Berhasil");
        }
    }
    catch (Exception ex)
    {
        MessageBox.Show("Koneksi Gagal : " + ex.Message);
    }
}
```

8. LANGKAH 8 – Menggunakan DataAdapter untuk Load Data
Ganti isi btnLoad_Click dengan:

```
private void btnLoad_Click(object sender, EventArgs e)
{
    LoadData();
}
```

Hasil:

- DataGridView terhubung ke BindingSource
- Textbox otomatis berubah saat navigator ditekan

9. LANGKAH 9 – INSERT Aman (Parameterized Query)
Gunakan:

```
private void btnInsert_Click(object sender, EventArgs e)
{
    try
    {
        if (conn.State == ConnectionState.Closed)
        {
            conn.Open();
        }

        if (txtNIM.Text == "")
        {
            MessageBox.Show("NIM harus diisi");
            txtNIM.Focus();
            return;
        }

        if (txtNama.Text == "")
        {
            MessageBox.Show("Nama harus diisi");
            txtNama.Focus();
            return;
        }

        if (cmbJK.Text == "")
        {
            MessageBox.Show("Jenis Kelamin harus dipilih");
            cmbJK.Focus();
            return;
        }

        if (txtKodeProdi.Text == "")
        {
            MessageBox.Show("Kode Prodi harus diisi");
            txtKodeProdi.Focus();
            return;
        }

        string queryProdi = @"Select count(KodeProdi), KodeProdi from Prodi where
        NamaProdi = @NmProdi Group By KodeProdi;";

        MySqlCommand cmd = new MySqlCommand(queryProdi, conn);
        cmd.Parameters.AddWithValue("@NmProdi", txtKodeProdi.Text);
        int result = Convert.ToInt32(cmd.ExecuteScalar());
    }
}
```

```

if (result == 0)
{
    string queryNmProdi = @"Select NamaProdi from Prodi";
    MySqlCommand MySqlcmd = new MySqlCommand(queryNmProdi, conn);
    MySqlDataReader rd = MySqlcmd.ExecuteReader();

    string nmProdi = "";
    while (rd.Read())
    {
        nmProdi = rd["NamaProdi"].ToString() + ";\n";
    }
    rd.Close();
    MessageBox.Show("Prodi Tidak Ditemukan!\nNama Prodi yang Terdaftar :\n\n" + nmProdi, "Peringatan",
        MessageBoxButtons.OK, MessageBoxIcon.Error);
}
else
{
    MySqlDataReader reader = cmd.ExecuteReader();
    string kodeProdi = "";
    while (reader.Read())
    {
        kodeProdi = reader["KodeProdi"].ToString();
    }

    reader.Close();
    string queryInsert = @"Insert into Mahasiswa
        (NIM,Nama,Alamat,JenisKelamin,TanggalLahir,KodeProdi,TanggalDaftar)
        values
        (@NIM,@Nama,@Alamat,@JenisKelamin,@TanggalLahir,@KodeProdi,@TanggalDaftar)";
    MySqlCommand command = new MySqlCommand(queryInsert, conn);

    command.Parameters.AddWithValue("@NIM", txtNIM.Text);
    command.Parameters.AddWithValue("@Nama", txtNama.Text);
    command.Parameters.AddWithValue("@Alamat", txtAlamat.Text);
    command.Parameters.AddWithValue("@JenisKelamin", cmbJK.Text);
    command.Parameters.AddWithValue("@TanggalLahir", dtpTanggalLahir.Value.Date);
    command.Parameters.AddWithValue("@KodeProdi", kodeProdi);
    command.Parameters.AddWithValue("@TanggalDaftar", DateTime.Now);

    result = command.ExecuteNonQuery();

    if(result > 0)
    {
        MessageBox.Show("Data mahasiswa berhasil ditambahkan");
        ClearForm();
        btnLoad.PerformClick();
    }
    else
    {
        MessageBox.Show("Data gagal ditambahkan");
    }
}

catch (Exception ex) {
    MessageBox.Show("Terjadi kesalahan: " + ex.Message);
}
}

```

10. LANGKAH 10 – UPDATE Aman (Parameterized Query)

Gunakan:

```
private void btnUpdate_Click(object sender, EventArgs e)
{
    try
    {
        if (conn.State == ConnectionState.Closed)
        {
            conn.Open();
        }
        string queryProdi = @"Select count(KodeProdi), KodeProdi from Prodi where
        NamaProdi = @NmProdi Group By KodeProdi;";

        MySqlCommand cmd = new MySqlCommand(queryProdi, conn);
        cmd.Parameters.AddWithValue("@NmProdi", txtKodeProdi.Text);
        int result = Convert.ToInt32(cmd.ExecuteScalar());

        if (result == 0)
        {
            string queryNmProdi = @"Select NamaProdi from Prodi";
            MySqlCommand MySqlcmd = new MySqlCommand(queryNmProdi, conn);
            MySqlDataReader rd = MySqlcmd.ExecuteReader();
            string nmProdi = "";
            while (rd.Read())
            {
                nmProdi = rd["NamaProdi"].ToString() + ";";
            }
            rd.Close();
            MessageBox.Show("Prodi Tidak Ditemukan!\nNama Prodi yang Terdaftar :\n\n"
                +nmProdi, "Peringatan", MessageBoxButtons.OK, MessageBoxIcon.Error);
        }
        else
        {
            MySqlDataReader reader = cmd.ExecuteReader();
            string kodeProdi = "";
            while (reader.Read())
            {
                kodeProdi = reader["KodeProdi"].ToString();
            }

            reader.Close();

            string query = @"Update Mahasiswa
            set Nama = @Nama,
            JenisKelamin = @JK,
            TanggalLahir = @TanggalLahir,
            Alamat = @Alamat,
            KodeProdi = @KodeProdi
            where NIM = @NIM";
            MySqlCommand command = new MySqlCommand(query, conn);

            command.Parameters.AddWithValue("@NIM", txtNIM.Text);
            command.Parameters.AddWithValue("@Nama", txtNama.Text);
            command.Parameters.AddWithValue("@Alamat", txtAlamat.Text);
            command.Parameters.AddWithValue("@JK", cmbJK.Text);
            command.Parameters.AddWithValue("@TanggalLahir", dtpTanggalLahir.Value.Date);
            command.Parameters.AddWithValue("@KodeProdi", kodeProdi);

            result = command.ExecuteNonQuery();

            if (result > 0)
            {
                MessageBox.Show("Data mahasiswa berhasil diubah");
                ClearForm();
                btnLoad.PerformClick();
            }
            else
            {
                MessageBox.Show("Data gagal diubah");
            }
        }
    }
    catch (Exception ex)
    {
        MessageBox.Show("Terjadi kesalahan: " + ex.Message);
    }
}
```


11. LANGKAH 11 – Ubah event datagrid_click()

```
private void dataGridView1_CellClick(object sender, DataGridViewCellEventArgs e)
{
    if (e.RowIndex >= 0)
    {
        DataGridViewRow row = dataGridView1.Rows[e.RowIndex];

        txtNIM.Text = row.Cells["NIM"].Value.ToString();
        txtNama.Text = row.Cells["Nama"].Value.ToString();
        cmbJK.Text = row.Cells["JenisKelamin"].Value.ToString();
        dtpTanggalLahir.Value = Convert.ToDateTime(row.Cells["TanggalLahir"].Value);
        txtAlamat.Text = row.Cells["Alamat"].Value.ToString();
        txtKodeProdi.Text = row.Cells["NamaProdi"].Value.ToString();
        txtNIM.Enabled = false;
    }
}
```

12. LANGKAH 12 – Script Reset Data Otomatis

a. Buat Backup Tabel (Sekali saja sebelum demo)

- Jika table backup belum ada

```
CREATE TABLE Mahasiswa_Backup AS
SELECT *
FROM mahasiswa;
```

- Jika table backup sudah ada

```
INSERT INTO Mahasiswa_Backup
SELECT *
FROM mahasiswa;
```

b. Tambahkan Event Pada Tombol Reset

```
private void btnReset_Click(object sender, EventArgs e)
{
    try
    {
        conn.Open();

        string deleteQuery = "DELETE FROM mahasiswa;";
        MySqlCommand cmdDelete = new MySqlCommand(deleteQuery, conn);
        cmdDelete.ExecuteNonQuery();

        string insertQuery = @"
INSERT INTO mahasiswa
SELECT * FROM mahasiswa_backup;";
        MySqlCommand cmdInsert = new MySqlCommand(insertQuery, conn);
        cmdInsert.ExecuteNonQuery();

        MessageBox.Show("Data berhasil direset");
        LoadData();
    }
    catch (Exception ex) {
        MessageBox.Show("Reset gagal: " + ex.Message);
    }
}
```

Fungsi:

- Menghapus seluruh data
- Mengembalikan dari tabel backup
- Recovery instan setelah demo

13. LANGKAH 13 – Simulasi MySQL Injection (Konseptual)

a. Tahap 1 – Membuat Versi Query Tidak Aman (Simulasi)

Tambahkan sementara button baru:

Nama tombol: **btnTestInjection**

Isi kode berikut:

```
private void btnTestInjection_Click(object sender, EventArgs e)
{
    try
    {
        if (conn.State == ConnectionState.Closed)
        {
            conn.Open();
        }

        string query = "Update mahasiswa set nama = 'HACKED' where NIM = " +
            txtNIM.Text;
        using (MySqlCommand cmd = new MySqlCommand(query, conn)) {
            int result = cmd.ExecuteNonQuery();
            MessageBox.Show(result + " baris berhasil diubah");
        }

        LoadData();
    }
    catch (Exception ex)
    {
        MessageBox.Show(ex.Message);
    }
}
```

b. Tahap 2 – Melakukan Uji Injection

Pada textbox txtNIM, masukkan: **" OR 1=1 --**

Kemudian klik tombol Test Injection.

The screenshot shows a Windows application window titled "Form1". It contains a data entry form with fields for NIM, Nama, Jenis Kelamin, Tanggal Lahir, Alamat, and Nama Prodi. There are buttons for Open, Reset Data, Insert, Test, Update, Delete, Load, and Refresh. The NIM field contains the text "OR 1=1 --". The Test button is highlighted. A message box is displayed in the center of the window with the text "2 baris berhasil diubah" and an OK button. Below the form is a table with the following data:

	NIM	Nama	JenisKelamin	TanggalLahir	Alamat	NamaProdi
▶	20250140001	Hari Panduanto	L	2/1/2002	Bantul, D.I. Yo...	Teknologi Infro...
	20250140002	Rini Suyanti	P	12/12/2002	Bantul	Teknologi Infro...

Tampilan sebelum injeksi

Form1

2 of 2

NIM

Nama

Jenis Kelamin

Tanggal Lahir

Alamat

Nama Prodi

Open Reset Data

Insert Test

Update

Delete

Load

Refresh

	NIM	Nama	JenisKelamin	TanggalLahir	Alamat	NamaProdi
	20250140001	Han Panduanto	L	2/1/2002	Bantul, D.I. Yo...	Teknologi Infro...
▶	20250140002	Rini Suyanti	P	12/12/2002	Bantul	Teknologi Infro...

Tampilan setelah injeksi

Form1

2 of 2

NIM

Nama

Jenis Kelamin

Tanggal Lahir

Alamat

Nama Prodi

Open Reset Data

Insert Test

Update

Delete

Load

Refresh

	NIM	Nama	JenisKelamin	TanggalLahir	Alamat	NamaProdi
	20250140001	HACKED	L	2/1/2002	Bantul, D.I. Yo...	Teknologi Infro...
▶	20250140002	HACKED	P	12/12/2002	Bantul	Teknologi Infro...

14. LANGKAH 14 – Kembalikan setingan awal MySQL Editor, sehingga database tidak bisa di inject kembali. (lakukan langkah ini ketika sudah menilaikan activity 9)

Buka Preferences... -> Buka MySQL Editor -> check list Safe Update -> click Ok -> Reopen MySQL Workbench -> Reconnect Server.

